TRABALHO PRÁTICO 3

Mensageria segura multi-cliente

Segurança da Informação

Criptografia ponta a ponta com servidor relay



Professor Michel Sales

Arquitetura e divisão da apresentação

Clientes

Cifram e decifram as conversas.
Guardam as chaves privadas e AES.

Servidor relay

Distribui chaves públicas autenticadas.
Encaminha os frames cifrados.

Pessoa 2

Cliente e criptografia E2E

Pessoa 1

Rede, sessões e autenticação

Framing TCP e sessões

Campo	Comprimento	Versão e tipo	Payload
Formato	4 bytes big-endian	1 byte + 1 byte	Conteúdo do frame

Leitura segura

Envelope de 2 a 65.536 bytes.
O relay valida o tamanho antes de ler o corpo.

Estado no servidor

UUID identifica a conexão ativa.
A sessão guarda chave pública e controles, sem chaves AES.

Autenticação do servidor

01 **Registro**

O cliente envia UUID e chave pública X25519 nova.

02 **Certificado e RSA-PSS**

O cliente compara o certificado com o pin e verifica a assinatura.

03 **Diretório autenticado**

Anúncios de peers vinculam destino, contexto e contador.

X25519 e derivação das chaves E2E

Um segredo compartilhado por par

Z_AB = X25519(sk_A, pk_B) = X25519(sk_B, pk_A)

HKDF-SHA256

O mesmo salt do par alimenta a derivação nos dois clientes.

Duas chaves de 16 bytes

A2B protege os envios de A para B. B2A protege a direção inversa.

AES-GCM, nonce e proteção contra replay

Nonce	Remetente	Destinatário	Contador	Texto cifrado	Tag
12 B	16 B	16 B	8 B	Até 4.096 B	16 B

Nonce por direção

IV base de 4 bytes + contador de 8 bytes.
Cada envio reserva um número novo.

Validação no destinatário

AAD autentica IDs e contador.
O cliente só avança o estado após validar a tag GCM.

Demonstração com três clientes

Pessoa 1: servidor

.venv/bin/python -m src.server.main

Pessoa 2: três terminais de cliente

.venv/bin/python -m src.client.main

A conversa com B. B responde. C recebe apenas o envio dirigido a C.

Adulteração e replay

Adulteração

Um bit muda no frame.
O destinatário rejeita a tag GCM.
O frame íntegro seguinte funciona.

--cenario adulteracao

Replay

O mesmo frame retorna.
O contador já foi aceito.
O destinatário rejeita a repetição.

--cenario replay

Framing inválido e isolamento da falha

0xffffffff

Comprimento fora do limite

O relay encerra a conexão ofensora antes de ler um corpo enorme.

Os três clientes legítimos continuam trocando mensagens.

Garantias e limites do projeto

Garantias demonstradas

AES-GCM protege o conteúdo.
Pin e RSA-PSS autenticam o servidor.
Contadores bloqueiam replay.

Limites do modelo

O diretório pressupõe relay confiável.
UUID não autentica uma pessoa.
IDs e padrões de tráfego ficam visíveis.

Chaves efêmeras descartadas protegem sessões passadas contra o comprometimento futuro apenas da chave RSA.

Reconexão e verificação do pin

Reconexão

O mesmo UUID inicia novo handshake.
Novas chaves invalidam frames antigos.

--cenario reconexao

Pinning

Um certificado diferente do configurado provoca rejeição.

--cenario pinning

Decisões do protocolo e referências

Decisão da implementação	Motivo
Salt comum para cada par	Os dois clientes precisam derivar as mesmas chaves.
RSA em DER/SPKI no material assinado	O enunciado não define um formato raw para RSA.
IV de recepção aprendido após tag válida	O receptor precisa usar o IV de envio do peer.

Código e documentação

github.com/Tito-Tiago/mensageria-segura-e2e